Authentification LDAP et LDAPS sur pfSense (Active Directory hermes)

Nom Prénom : **Dylan Spinelli**

BTS SIO SISR

Paris Ynov Campus

Sommaire

A- Test de la connectivité LDAP et LDAPS sur le serveur active directory hermes.....1

a. Connectivité LDAP.....1

b. Connectivité LDAPS (LDAP sur SSL).....2

B- Création d'une autorité de certification sur le contrôleur de domaine hermes.....2

a. Ajouter le rôle certificat sur hermes.....2

b. Configuration du rôle certificat sur hermes.....4

C- Test de la connectivité LDAP et LDAPS (LDAP sur SSL) sur heimdall (pfsense).....8

D- Création des comptes utilisateurs sur le contrôleur de domaine.....9

E- Création des authentifications LDAP et LDAPS sur le serveur pfsense.....10

a. Création de l'authentifications LDAP.....10

b. Création de l'authentifications LDAPS.....11

c. Création du formulaire de l'authentification LDAPS.....11

d. Analyse avec Wire Shark du trafic pfsense active directory.....12

e. Exportation du certificat de l'autorité de certification hermes.....12

f. Importation du certificat de l'autorité de certification racine.....14

g. Test de la connexion ssl entre pfsense et le contrôleur de domaine.....15

F- Utilisation des authentifications LDAP et LDAPS sur le serveur pfsense.....15

a. Vérification de l'authentification LDAP et LDAPS.....15

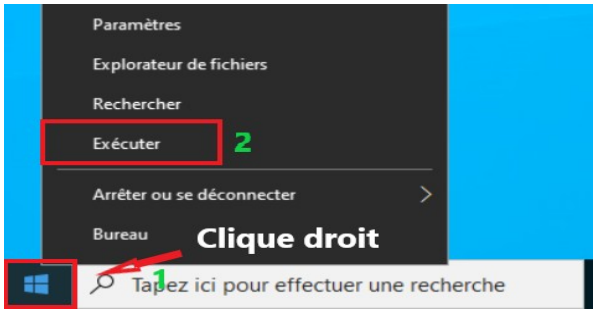
b. Configuration des groupes et des utilisateurs sur pfsense.....16

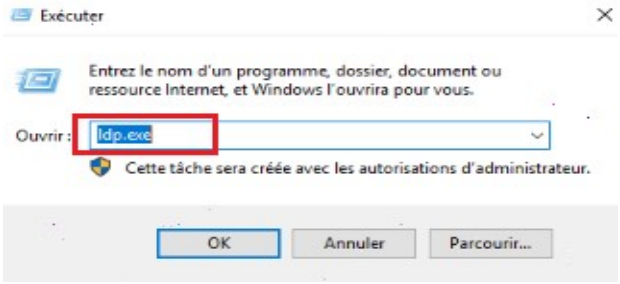
A- Test de la connectivité LDAP et LDAPS sur le serveur active directory hermes

Contexte (plateforme 1, domaine sitka.local) : le contrôleur de domaine et serveur DNS est hermes (hermes.sitka.local, 172.20.1.2) et le pare-feu pfSense est heimdall (172.20.1.1), tous deux dans le VLAN 10 - Administration (172.20.1.0/24).

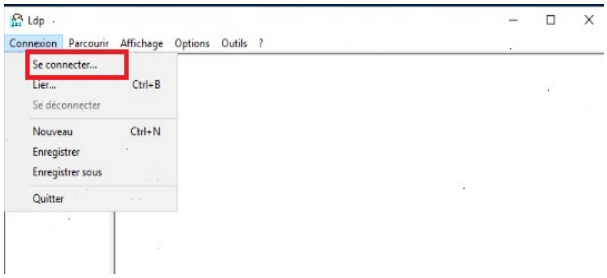
a. Connectivité LDAP

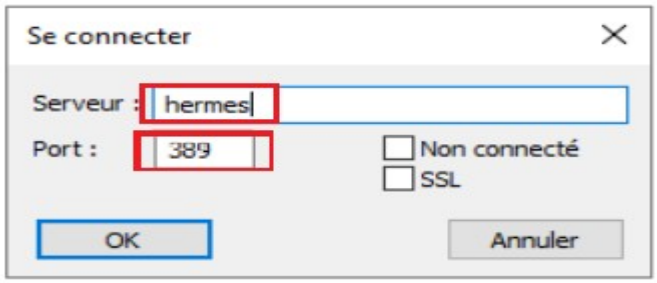
Sur le contrôleur de domaine on test la connectivité LDAP standard, donc clique droit sur le menu démarrer + exécuter puis on tape **ldp.exe** pour ouvrir l'explorateur LDAP



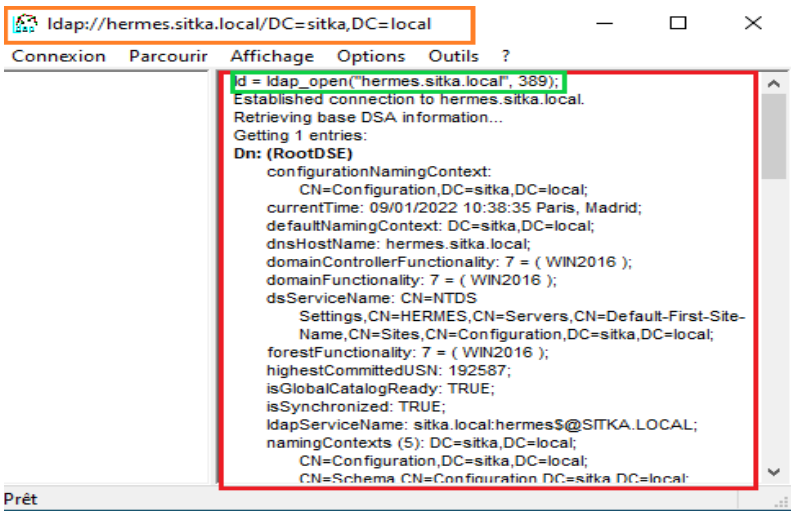


Un fois l'explorateur LDAP est ouvert l'explorateur on choisit le menu Se connecter et on rentre le nom du serveur **hermes.sitka.local** ainsi que le port de connexion **389**



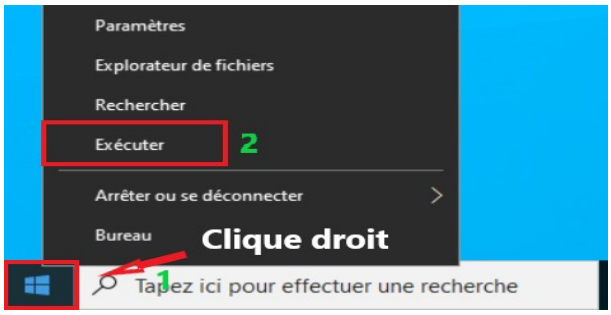


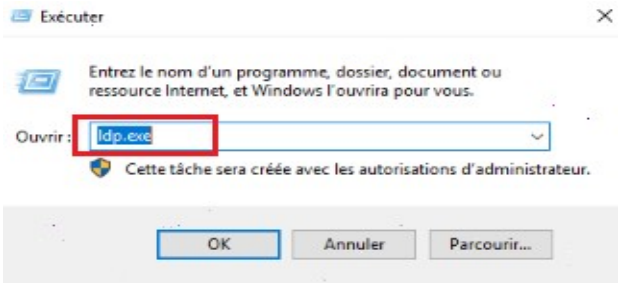
La connexion à la base d'annuaire fonctionne on peut identifier les partitions d'annuaire



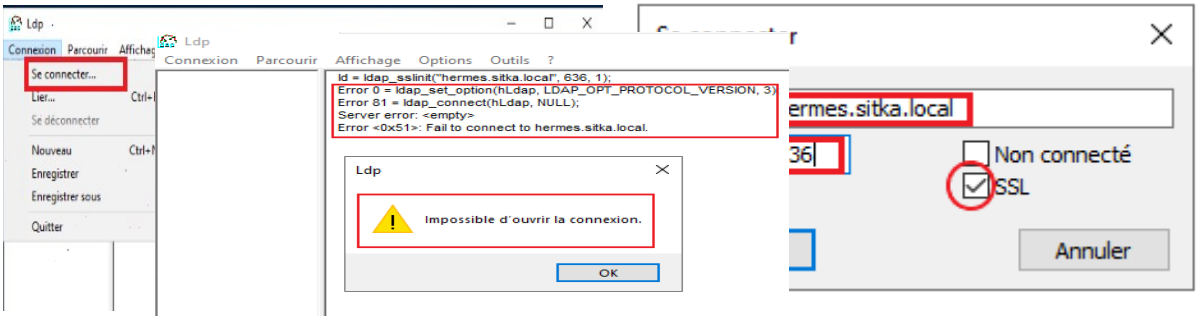
b. Connectivité LDAPS (LDAP sur SSL)

On fait la même chose que la procédure établissant une connexion standard on change juste le numéro de port et on coche ssl





On tombe sur un message d'erreur, le contrôleur de domaine ne supporte pas LDAPS car il n'est pas associé à un certificat.



Il existe deux méthodes pour activer LDAPS (LDAP sur SSL) sur un contrôleur de domaine :

- Mettre un Certificat Racine sur le contrôleur de domaine en installant une autorité de certification racine sur hermes
- Utiliser un certificat tiers sur le contrôleur de domaine. (Hermes)

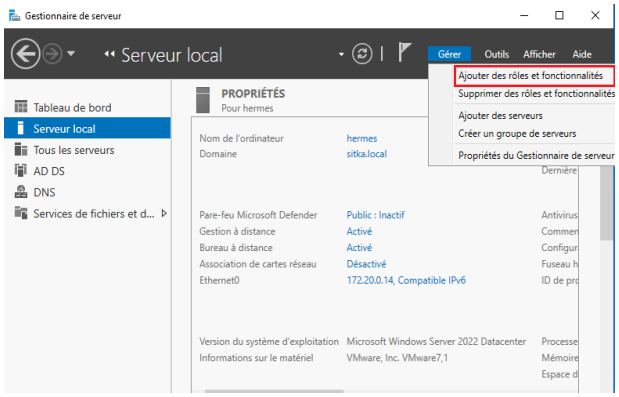
Pour notre procédure on choisira la première méthode, Donc il faut installer une autorité de certification afin de tirer parti de LDAPS

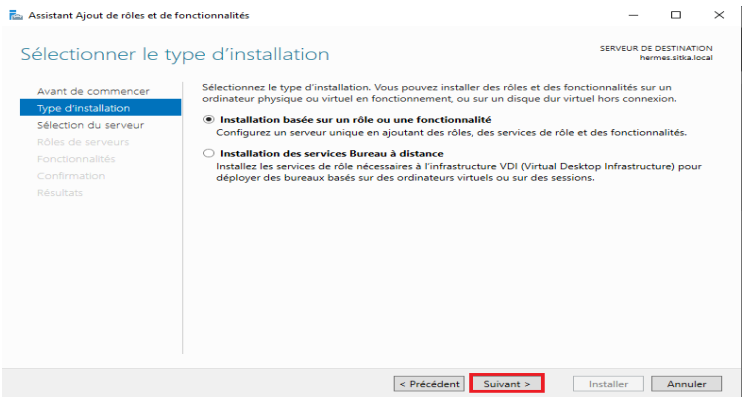
B- Création d'une autorité de certification sur le contrôleur de domaine hermes

Il est nécessaire d'installer le service autorité de certification. Pour fournir au contrôleur de domaine un certificat qui permettra au service LDAPS d'opérer sur le port 636.

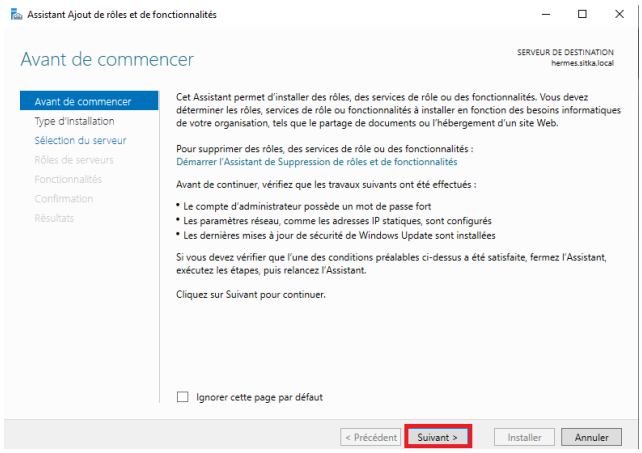
a. Ajouter le rôle certificat sur hermes

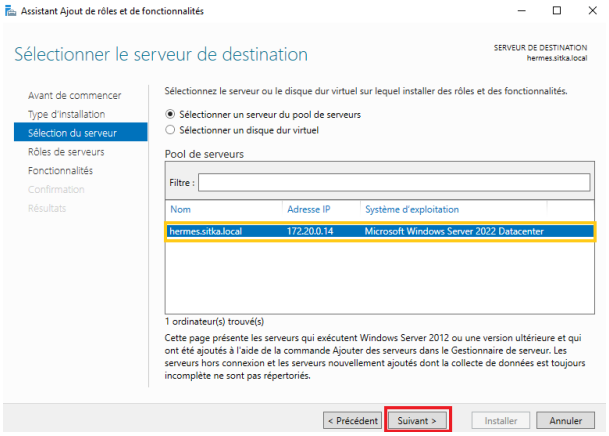
Accédez au menu Gérer et cliquez sur Ajouter des rôles et des fonctionnalités.



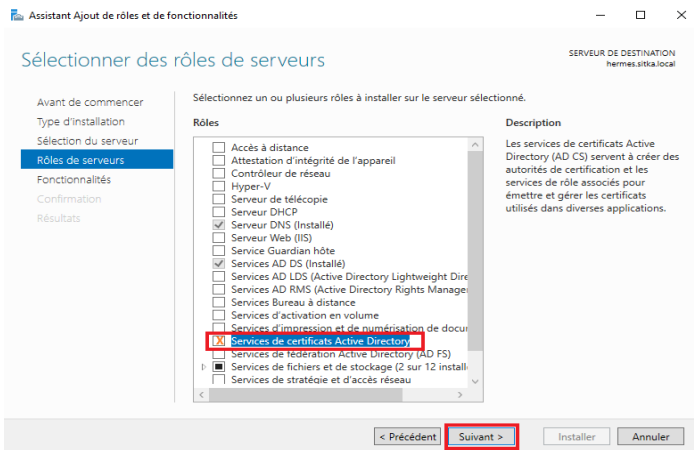


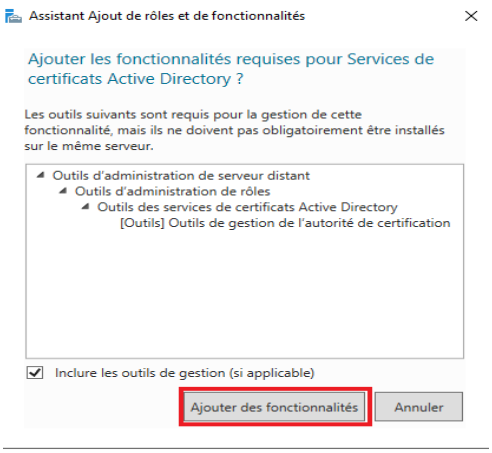
On vérifie le nom et l'adresse IP de notre serveur on clique après sur suivant



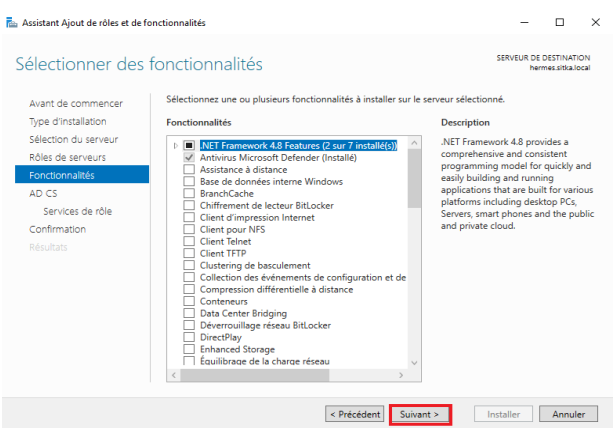


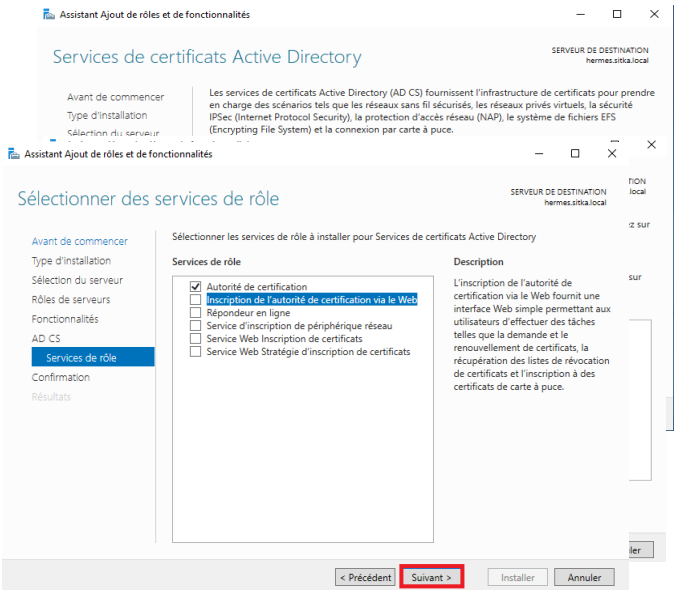
On coche Services de Certificats Active Directory et on rajoute les fonctionnalités





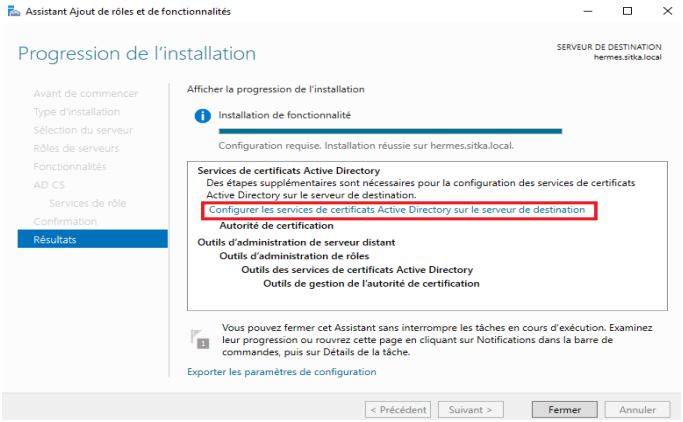
Sur les deux Boites de dialogues ci-dessous on laisse tout par défaut en faisant suivant.





On sélectionne que l'option Autorité de certification

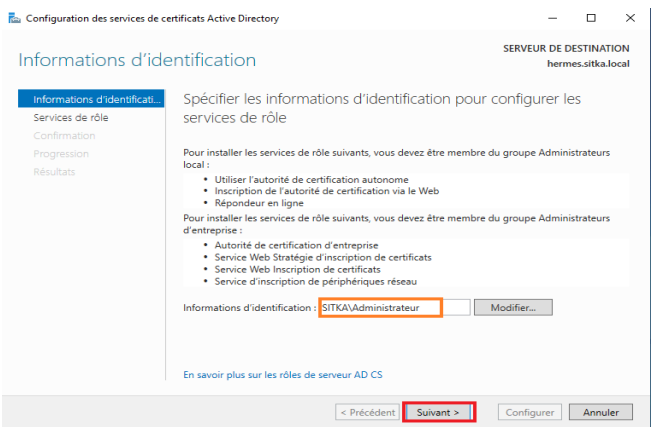
Dernière étape on clique sur le lien Configurer les services Active Directory sur le serveur de destination

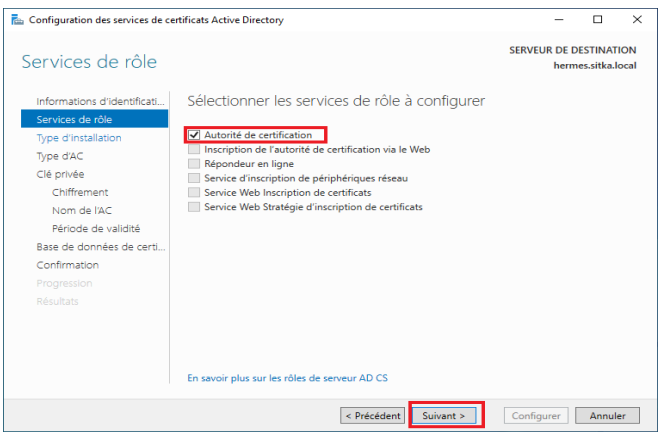


b. Configuration du rôle certificat sur hermes

Une fois le rôle certificat est installé il faut maintenant le configurer, on vérifie les informations d'identification, il est obligatoire d'être connecté avec le compte de l'administrateur de l'entreprise (domaine\administrateur).

On coche après Autorité de certification, toutes les autres options on peut les installer après au besoin



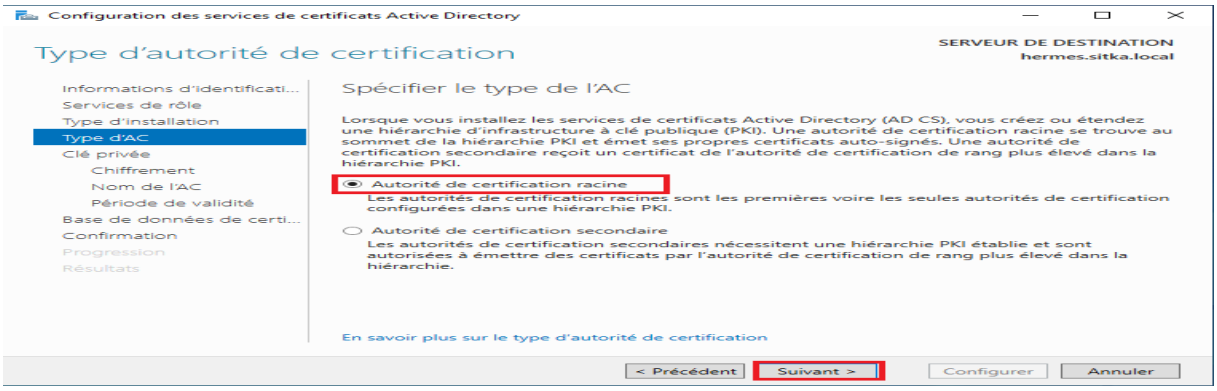


On sélectionne Autorité de certification d'entreprise afin que l'autorité de certification puisse utiliser l'annuaire LDAP

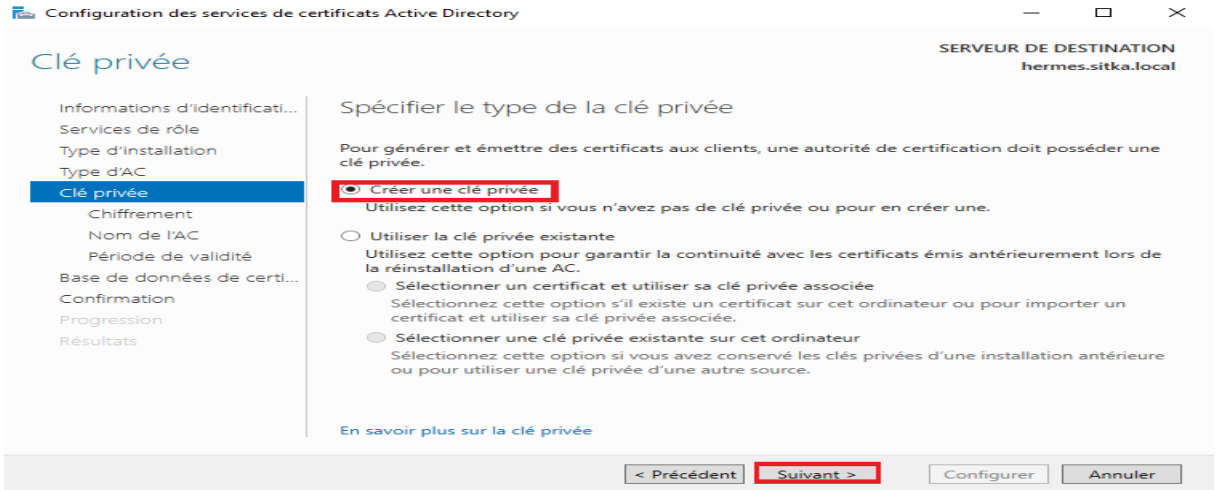


On sélectionne autorité de certification racine

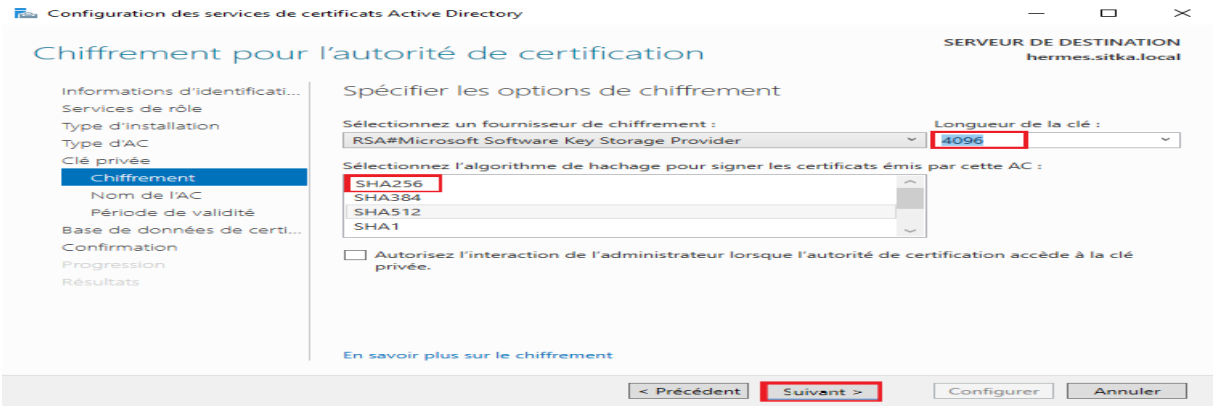
Ce type d'autorité de certification couplé avec un Active Directory est utile pour un intranet mais est déconseillée pour un accès public. Puisque notre autorité n'est pas listée parmi les autorités de certification de confiance, les personnes utilisant des certificats émis par notre autorité de certification auront un avertissement mentionnant que nos certificats ne sont pas de confiance.



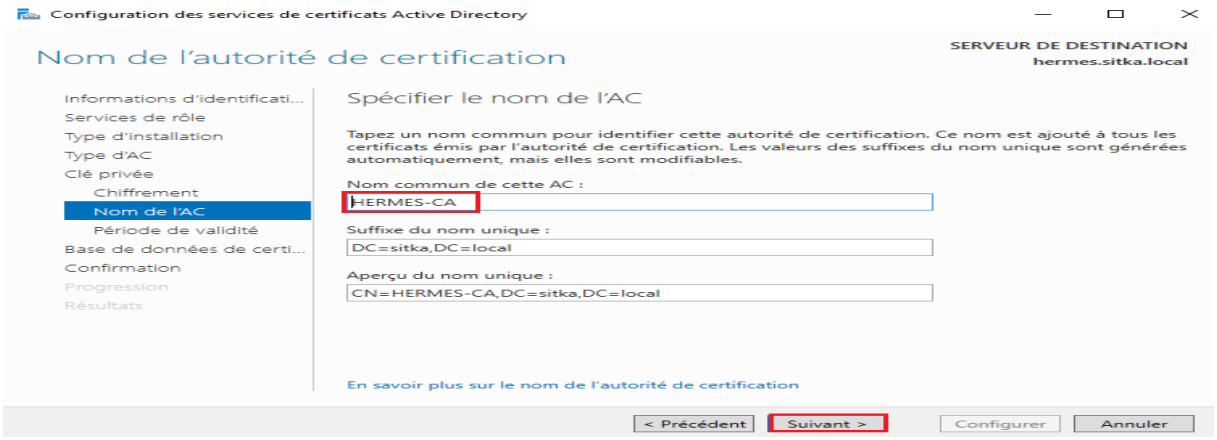
On choisit de créer une clé privée



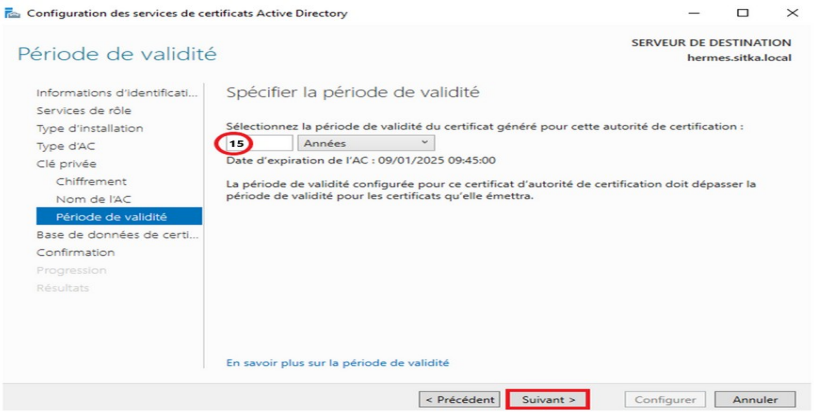
On choisit nos clés de chiffrage, plus les clés sont longues plus la sécurité est renforcée mais malheureusement les performances vont être impactées.



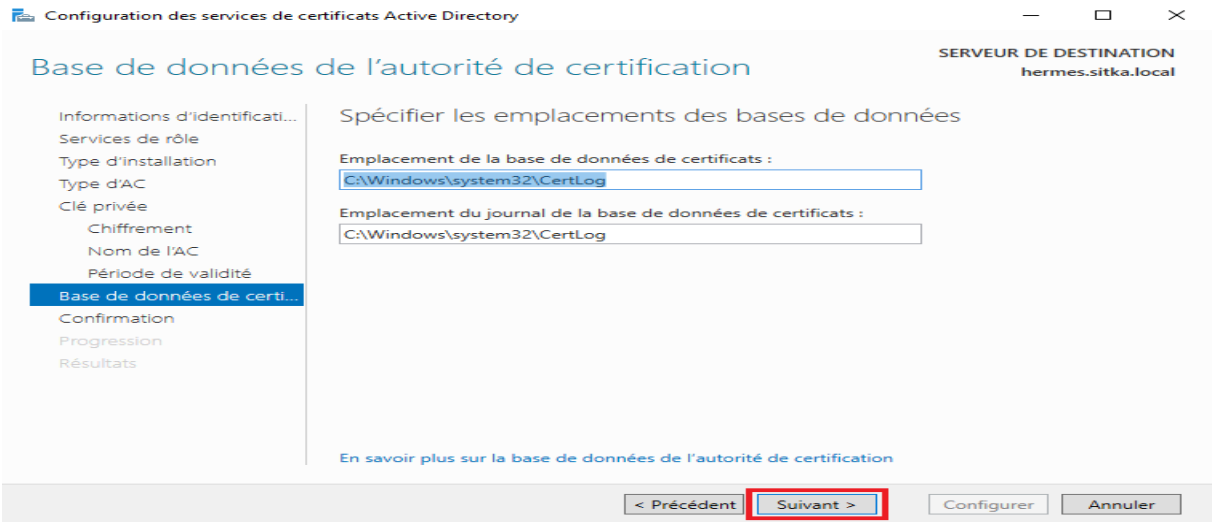
On peut modifier les valeurs par défaut ; je choisis hermes-CA comme nom commun de ACR



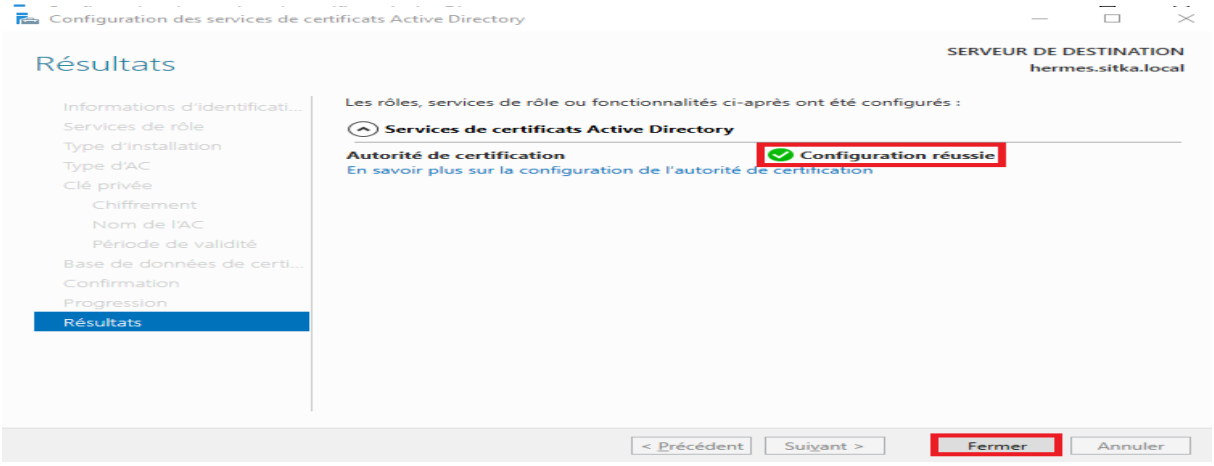
On rentre le période de validité pour le certificat de l'ACR., la période de validité du certificat de l'autorité de certification doit dépasser la période de validité des certificats émis.



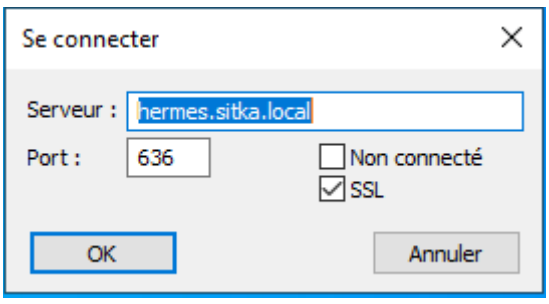
On laisse les dossiers des bases de données et des logs, par défaut.



L'assistant nous affiche un résumé de la configuration choisit, on lance ensuite le processus de Configuration
On doit obtenir le message configuration réussie



On reteste maintenant notre connexion LDAPS à partir de l'explorateur LDAP
La connexion sécurisée utilisant le **ssl** sur le port **636** à la base d'annuaire fonctionne on peut identifier les partitions d'annuaire



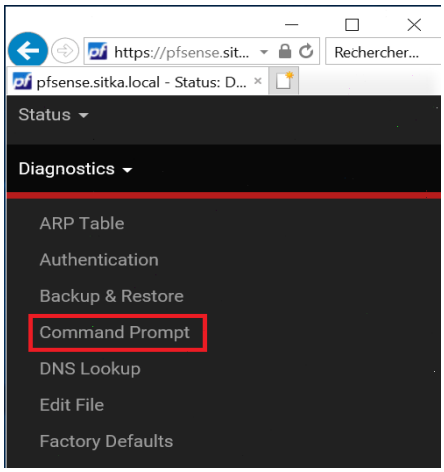


C- Test de la connectivité LDAP et LDAPS (LDAP sur SSL) sur heimdall (pfsense)

Sur pfsense on test la connexion de pfsense à la base d'annuaire du controleur de domaine en tapant la commande suivante soit en ssh ou derectement sur pfsense:

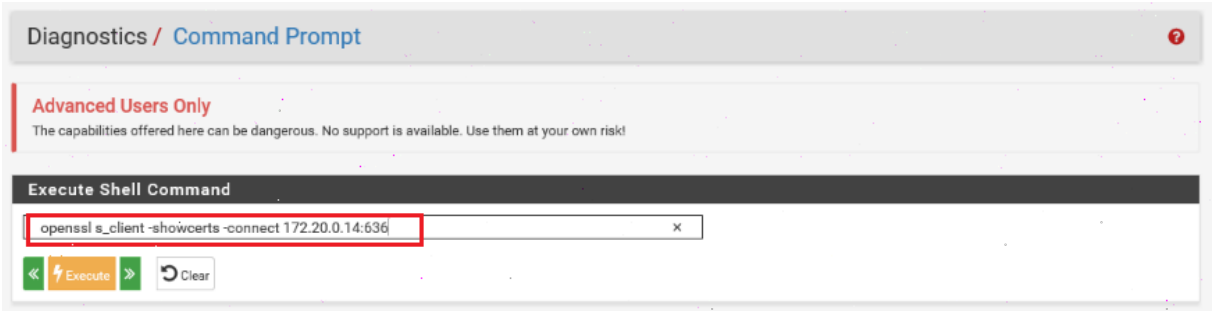
```
# openssl s_client -showcerts -connect 172.20.0.14:636 |less
```

On peut faire la meme chose sur l'interface web de pfsense pour tester la connexion de pfsense à la base d'annuaire du controleur de domaine, donc on va sur **Diagnostics** + **Command Prompt**



On tape la commande suivante :

```
openssl s_client -showcerts -connect hermes.sitka.local:636
```



Le contrôleur de domaine nous envoie le certificat qu'il utilise pour appliquer le ssl

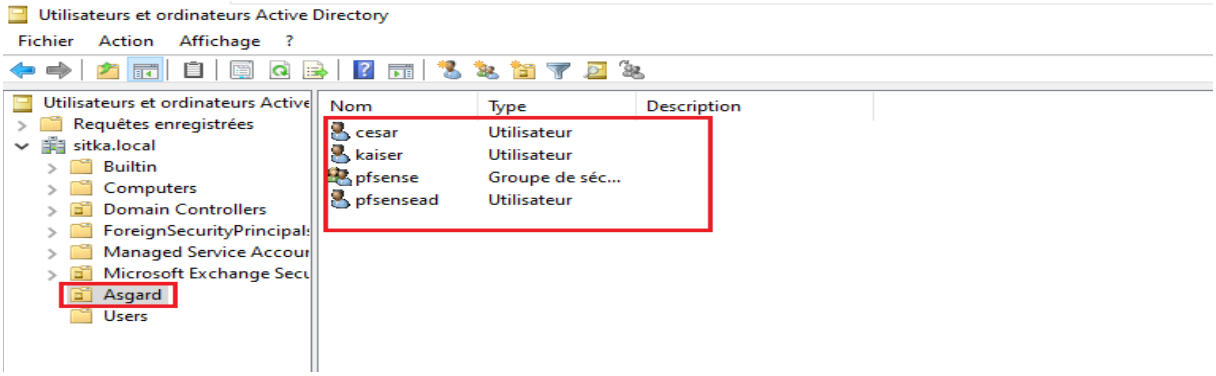
Shell Output - openssl s_client -showcerts -connect hermes.sitka.local:636

```
depth=0 CN = hermes.sitka.local
verify error:num=20:unable to get local issuer certificate
verify return:1
depth=0 CN = hermes.sitka.local
verify error:num=21:unable to verify the first certificate
verify return:1
depth=0 CN = hermes.sitka.local
verify return:1
CONNECTED(00000003)
---
Certificate chain
 0 s:CN = hermes.sitka.local
   i:DC = local, DC = sitka, CN = HERMES-CA
-----BEGIN CERTIFICATE-----
MIIG0zCCBLugAwIBAgITEgAAAAJXCyfPesdnYgAAAAAAAjANBgkqhkiG9w0BAQ0F
ADBCMRUwEwYKCZImiZPyLGQBGRYFbG9jYWwxFTATBgoJkiaJk/IsZAEZFgVzaXRr
YTESMBAGA1UEAxMJSEVSTUVTLUNBMB4XDTIyMDEwOTA4NDIzOFoXDTIzMDEwOTA4
NDIzOFowHTEbMBkGA1UEAxMSaGVybWVzLnNpdGthLmxvY2FsMIIBIjANBgkqhkiG
9w0BAQEFAAOCAQ8AMIIBCgKCAQEAvHhs5UeELmjovxUSPf8XRlqDa9gIsff7R10M
42lsBUP67Nya73IUDqYQ8QsQmzaqkgNDqaQXdO8Bdqq89rbZxa6QIGPHURHr8Edu
ANZxtntbM1c0rCp3RnQS1PDq4mNJ3XvL+IU82oR4nBZ34minC6rQa20N/kNw+UwW
EaEDHMgQplVc7NvEfJU5Y5CMpioz1x+NQDexHl1/EW1h6k5qBPaPj2CUFzTxTB/r
baOpNhI+A6d4fMWRsetDimC6xEhIKy82sZg/+1K2fJzHlFYeTTIBV2jw6qTXqlCA
DTf1adu2EJiXwUmxG2uM6Gbfd0wH6kSOQRrKNxdDQgJD5euLFQIDAQABo4IC5TCC
AuEwLwYJKwYBBAGCNxQCBCIeIABEAG8AbQBhAGkAbgBDAG8AbgB0AHIAbwBsAGwA
ZQByMB0GA1UdJQQWMBQGCCsGAQUFBwMCBggrBgEFBQcDATAOBgNVHQ8BAf8EBAMC
BaAweAYJKoZIhvcNAQkPBGswaTAOBggqhkiG9w0DAgICAIAwDgYIKoZIhvcNAwQC
AgCAMAsGCWCGSAFlAwQBKjALBglghkgBZQMEAS0wCwYJYIZIAWUDBAECMAsGCWCG
SAFlAwQBBTAHBgUrDgMCBzAKBggqhkiG9w0DBzAdBgNVHQ4EFgQUg6yhqFRdi13l
c8ttWCd0/2ineRMwHwYDVR0jBBgwFoAUBV88XfZiRChIBMqLFpBDLkHNf/QwgcYG
A1UdHwSBvjCBuzCBuKCBtaCBsoaBr2xkYXA6Ly8vQ049SEVSTUVTLUNBLENOPWhl
cm1lcyxDTj1DRFAsQ049UHVibGljJTIwS2V5JTIwU2VydmljZXMsQ049U2Vydmlj
ZXMsQ049Q29uZmlndXJhdGlvbixEQz1zaXRrYSxEQz1sb2NhbD9jZXJ0aWZpY2F0
ZVJldm9jYXRpb25MaXN0P2Jhc2U/b2JqZWN0Q2xhc3M9Y1JMRGlzdHJpYnV0aW9u
UG9pbnQwgbsGCCsGAQUFBwEBBIGuMIGrMIGoBggrBgEFBQcwAoaBm2xkYXA6Ly8v
Q049SEVSTUVTLUNBLENOPUFJQSxDTj1QdWJsaWMlMjBLZXklMjBTZXJ2aWNlcyxD
Tj1TZXJ2aWNlcyxDTj1Db25maWd1cmF0aW9uLERDPXNpdGthLERDPWxvY2FsP2NB
Q2VydGlmaWNhdGU/YmFzZT9vYmplY3RDbGFzcz1jZXJ0aWZpY2F0aW9uQXV0aG9y
aXR5MD4GA1UdEQQ3MDWgHwYJKwYBBAGCNxkBoBIEEBkHzD9EAy1Gi0BTfWocpG2C
Emhlcm1lcy5zaXRrYS5sb2NhbDANBgkqhkiG9w0BAQ0FAAOCAgEAF39BzYd7SShP
uWyP5C8O+YbDONHXcVec1ABJgp2jhMj3itAH4a7TKDXKXWbXjNtguBT1IIUzuwwh
jw6T1w50yj1Z+WUHoJfujuIwInVTjHFmgouH6UP7BwC7KTz+iiwH30HPXVMKixVR
t0EyzZqrS8drkcli5PfgU1BJq3L8fF3vqK3CVv/Ffd/Uagy+Qfb2WHDMIeCqc6e
IQYnbBNmLcWcqLVgfyE6sybtJ6NLqI8RZ7JB4QMAtrgCB60eiM8GARu6JkGs7jc2
SOLzXM4hFVMKberhHdQt4cE77kfGOoGjUmDoJDHDJuGkRWjQQ81W6pS9C11ld0lH
uiXAx9k2WTXSzvZIF6WObuW0v4gA+yZOF4+dgN+1+PRpM/Hxcn2VE7UXArVflm/Y
48KQEE84fCWly/LrVYxi9hoGdbM7pkTrRT0bp1vbUItcyaAVHC06zpX7y2ACGGrO
Kmi99AfKj5arlRLR6b/8uDfqCTBdc3BVjSugJ0KxSaISK0tSIrr/tU/KGve6B1G9
6WPoUzEb21+iRd2oT62tyPQ06lBsRktBLFSyPjioljrH/PKNp//FlMFAjAfHqalp
aAg1Jj5ETCWdR4ELyzB2kEMJUrRHxuutckNq8brhGZSdKUgAA5mh1vMr/bVTFCIw
wAHDHEXmYpTKPz5lF6FlinOi0BSylLM=
-----END CERTIFICATE-----
```

D- Création des comptes utilisateurs sur le contrôleur de domaine

Sur le contrôleur de domaine je crée :

- Un groupe **pfsense**
- Un utilisateur **kaiser** faisant partie du groupe **pfsense**
- Un utilisateur **cesar** faisant partie du groupe **pfsense**
- Un utilisateur **pfsensead** faisant partie du groupe **pfsense** et qui va servir de faire la liaison entre pfsense et le contrôleur de domaine



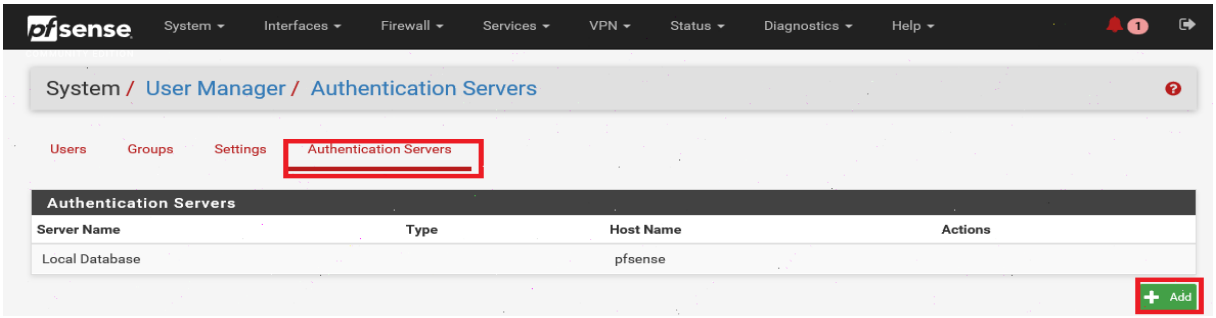
E- Création des authentifications LDAP et LDAPS sur le serveur pfsense

Sur pfsense il existe déjà une base locale permettant l'authentification des utilisateurs.
On va utiliser deux autres méthodes qui permettrons l'authentification en utilisant LDAP et LDAPS

a. Création de l'authentifications LDAP

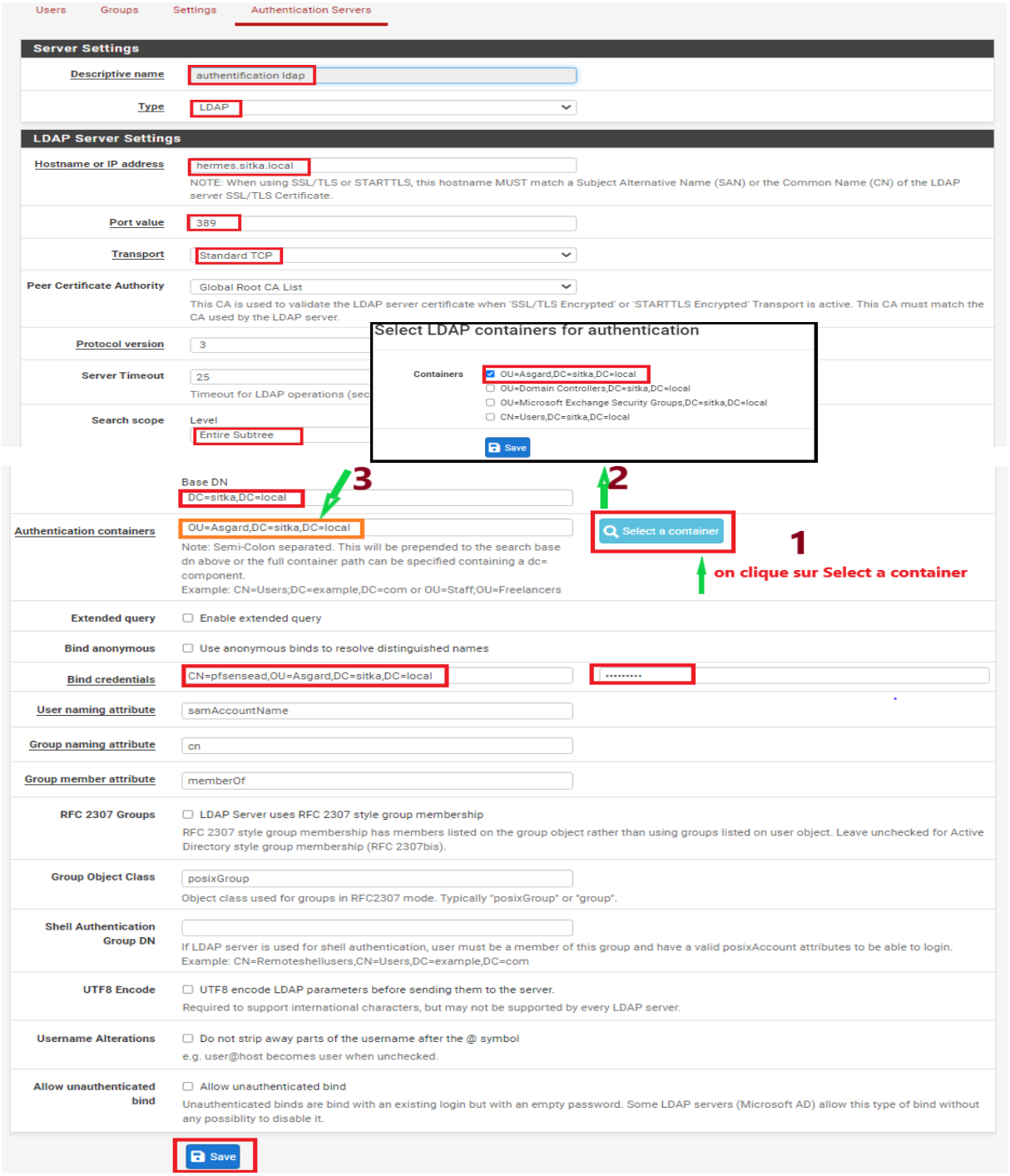
Maintenant on va créer une authentification LDAP sur pfsense à partir l'interface web on va sur System / User Manager / Authentication Servers

Et on clique sur + Add pour rajouter une authentification Servers



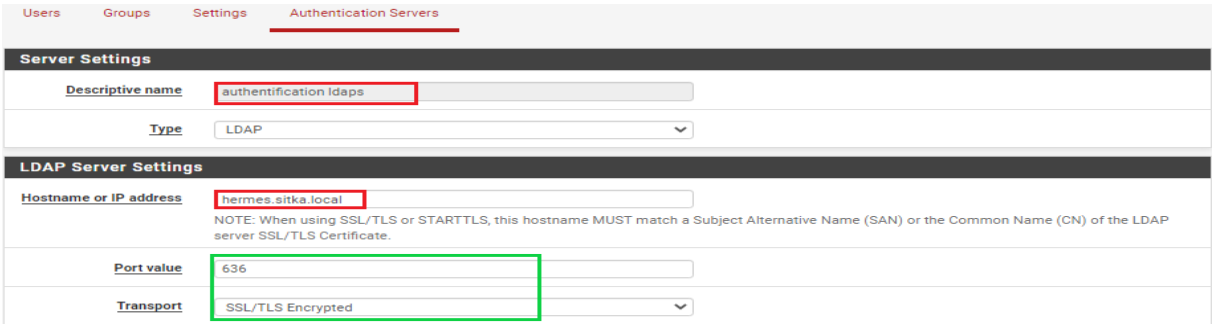
On remplit Les champs comme indiqué ci-dessous, les étapes 1,2 et 3 il faut les exécuter à la fin de notre procédure les faires : on tape cn dans le champ **Authentification containers** puis on clique sur **select a container**





b. **Création de l'authentifications LDAPS**

c. Création du formulaire de l'authentification LDAPS



Même procédure que l'authentification LDAP sauf pour les champs encadrés en **vert** on fait le choix de **SSL/TLS** et en utilise le port **636**

Dans **authentification containers** on tape cn puis on clique sur Select a container



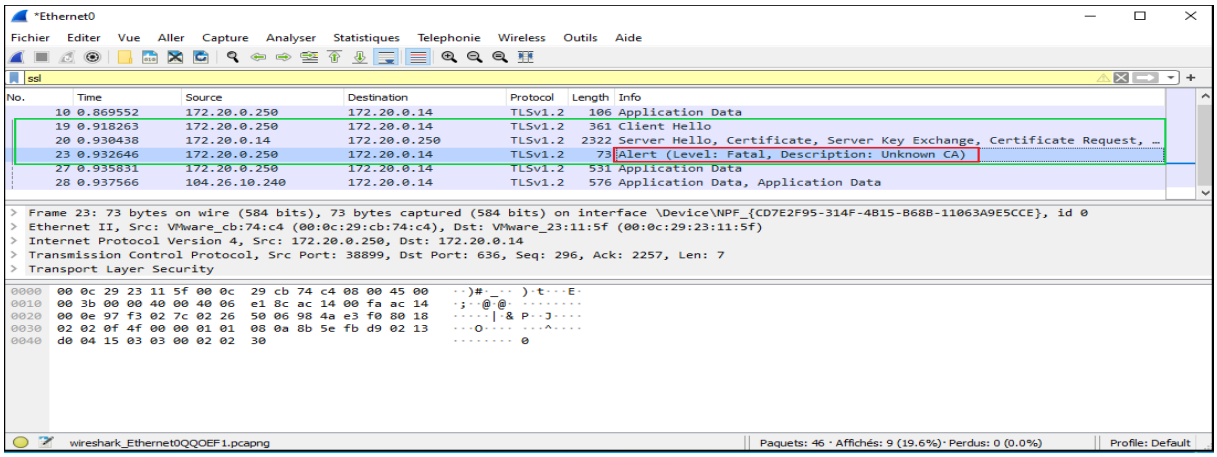
La boite de dialogue qui nous permet de choisir l'OU qui héberge nos utilisateurs ne s'ouvre pas en plus on a un message d'erreur qui apparait en bas de la page



d. Analyse avec Wire Shark du trafic pfsense active directory

Donc l'authentification LDAPS ne fonctionne pas, on va essayer de faire un diagnostic en faisant une capture de trames avec Wire Shark pour identifier le problème.
On installe Wire Shark sur notre contrôleur de domaine, puis on déclenche une capture de trame en même temps on exécute la manipulation précédente
On fait un filtre ssl/tls dans notre capture de trame
Les trames qui représentent l'échange entre pfsense et le contrôleur de domaine sont encadrée en vert :

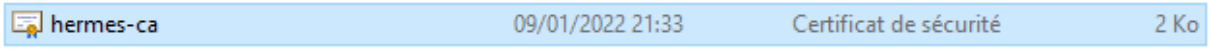
- Le dialogue commence par **client hello** la source est pfsense destination le hermes
- Hermes répond par **server hello** et présente son certificat à pfsense
- Pefsense répond par une alerte il ne reconnait pas le certificat

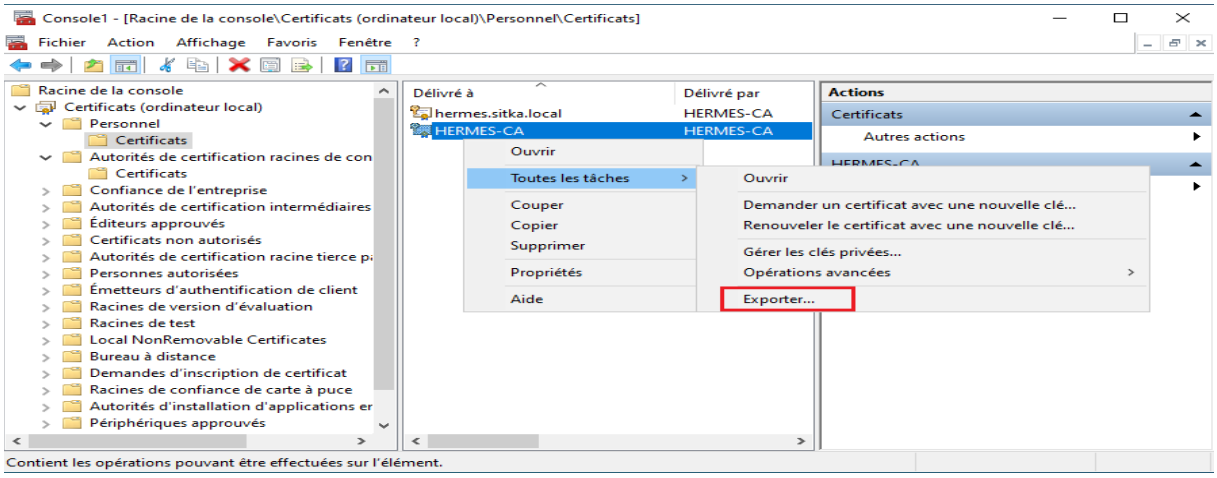


Donc le souci vient du fait que le certificat présenté par Hermes n'est pas reconnu par pfsense **pour contourner ce problème on va importer le certificat de l'autorité de certification racine installée sur hermes sur notre serveur pfsense.**

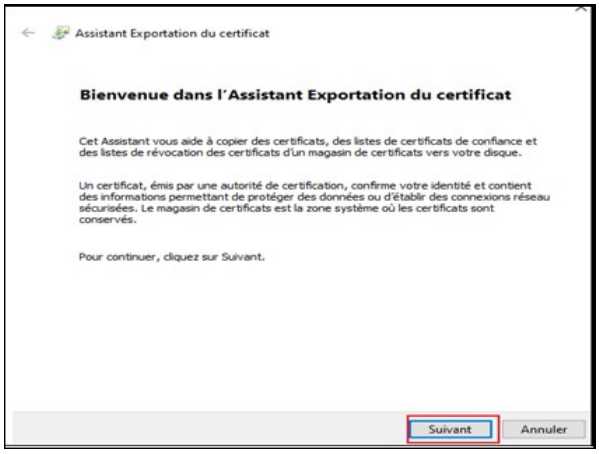
e. Exportation du certificat de l'autorité de certification hermes

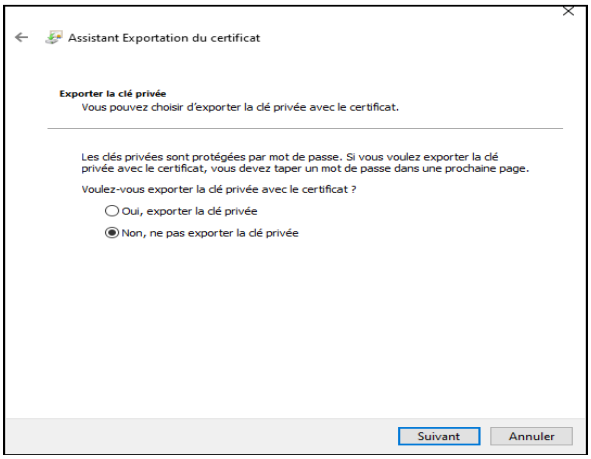
- On ouvre une console mmc et on rajoute Ajouter/Supprimer un composant logiciel enfichable... le composant certificat pour ordinateur
- On exporter le certificat de l'autorité de certification racine au format '.cer' on l'enregistre avec le nom qu'on choisit



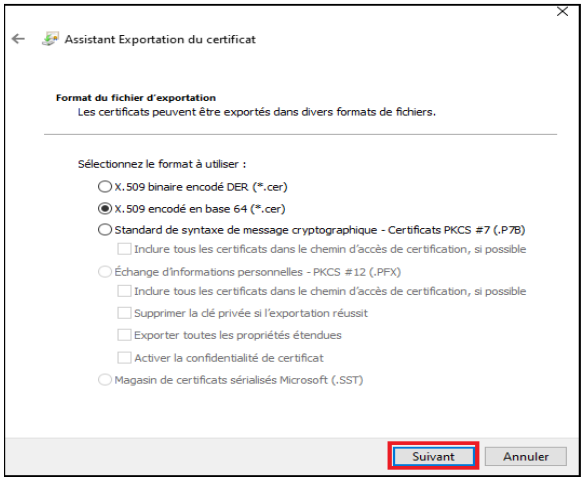


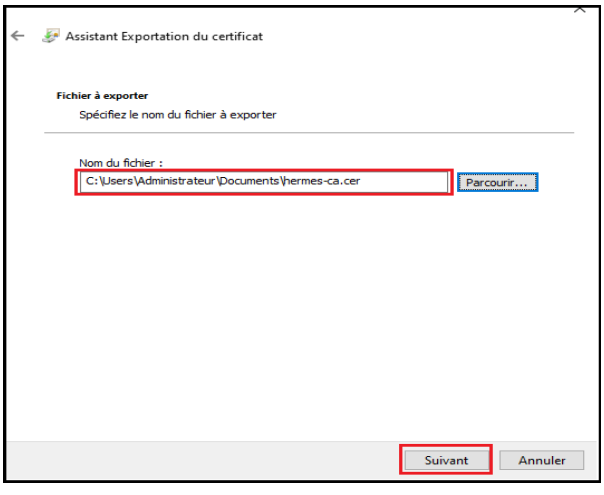
On choisit de ne pas exporter la clé privée



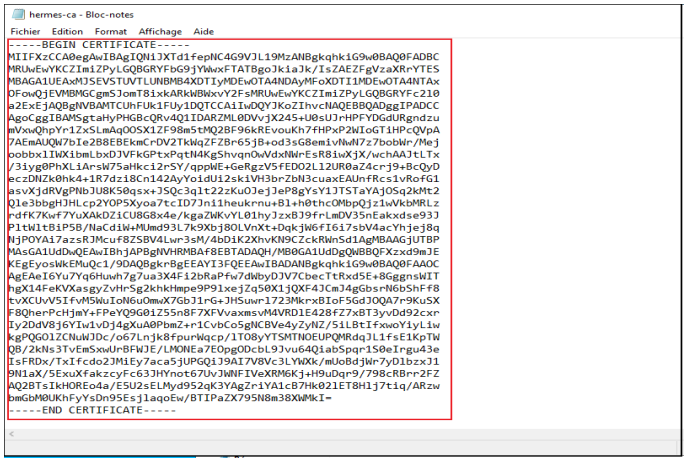


On choisit le format **X.509 encodé DER (*.cer)** et en l'enregistre avec le nom hermes-ca.cer



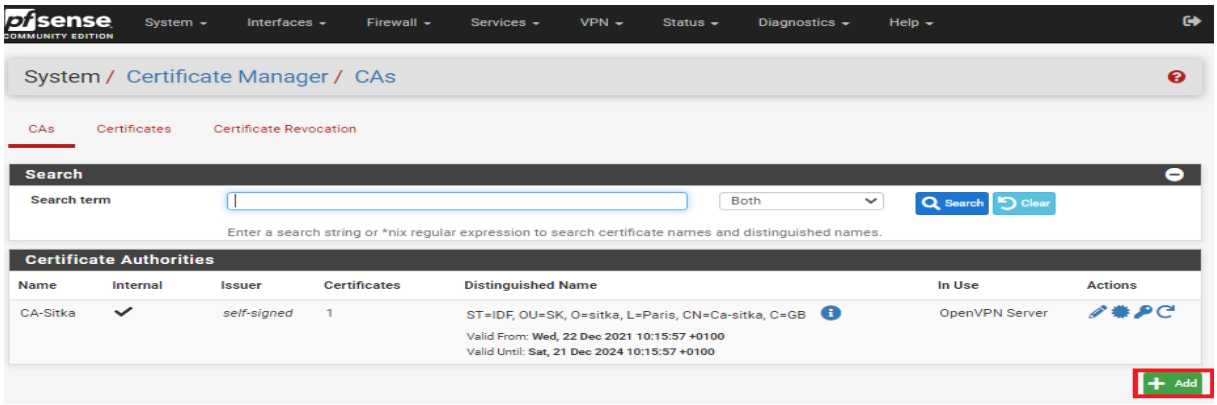


- J’ouvre mon fichier hermes-ca.cer avec le bloc note pour afficher le certificat de l’autorité de certification après on le copie pour l’insérer dans pfsense



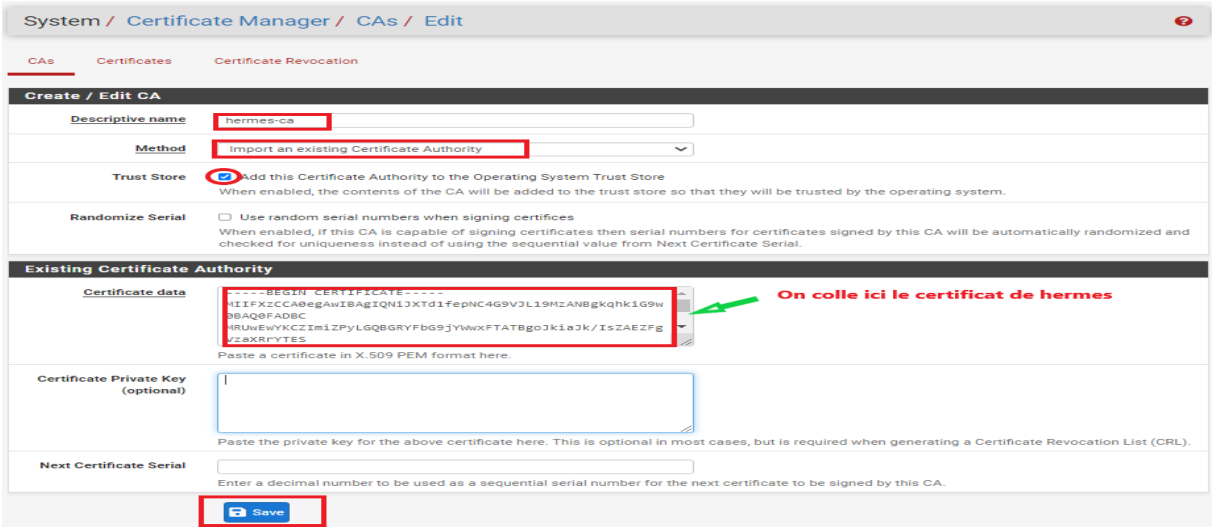
f. Importation du certificat de l’autorité de certification racine

On va sur **certificate manager + Cas** on clique sur ad pour rajouter une autorité de certification



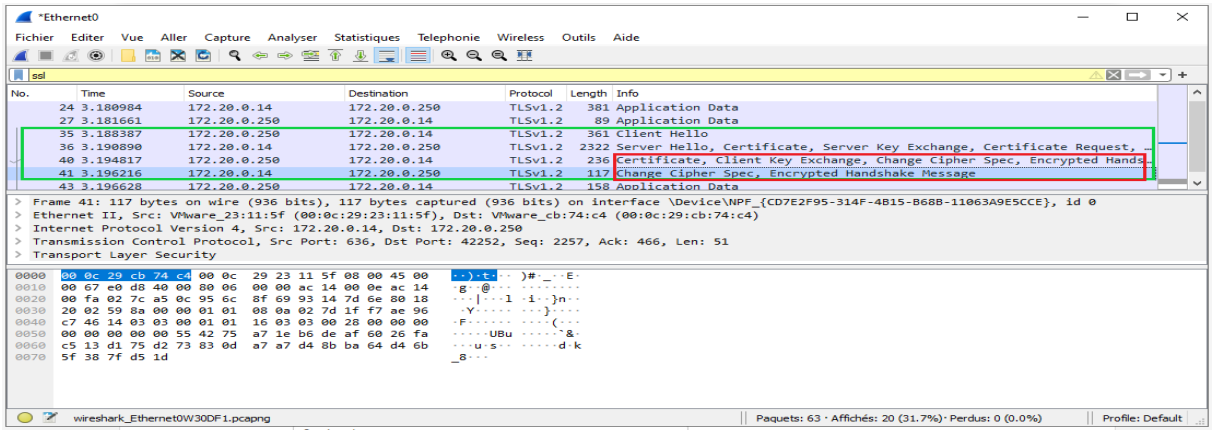
On donne un nom à notre autorité de certification et on choisit comme méthode **import an existing Certificate Autority**

Apres il suffit de coller le certificat de l’autorité de certification racine hermes dans le champ **certificate data**



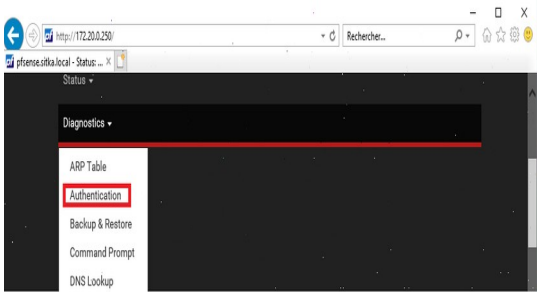
g. Test de la connexion ssl entre pfsense et le contrôleur de domaine

On constate qu'il n'y'a plus de messages d'erreurs que le message handshake (poignée de main) est établie et crypté on peut maintenant revenir pour terminer de remplir notre formulaire authentification LDAPS



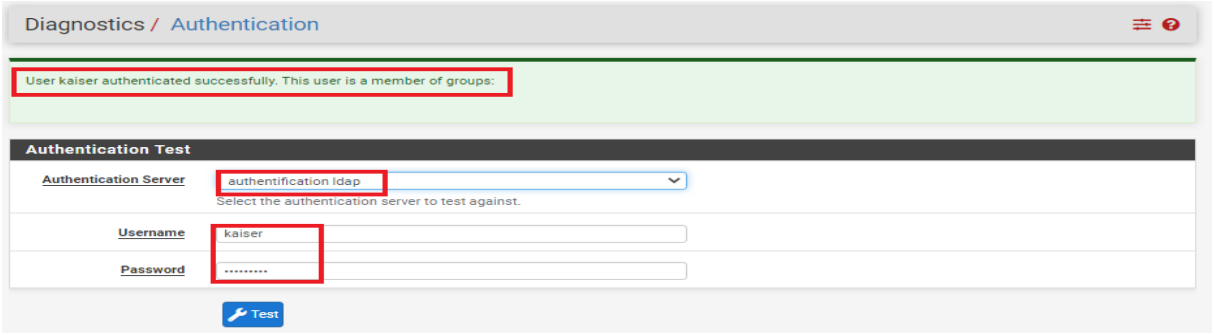
F- **Utilisation des authentifications LDAP et LDAPS sur le serveur pfsense**

Je vérifie l'authentification Active directory de mon compte **kaiser** à partir de l'interface web de pfsense, on va sur diagnostic + authentification

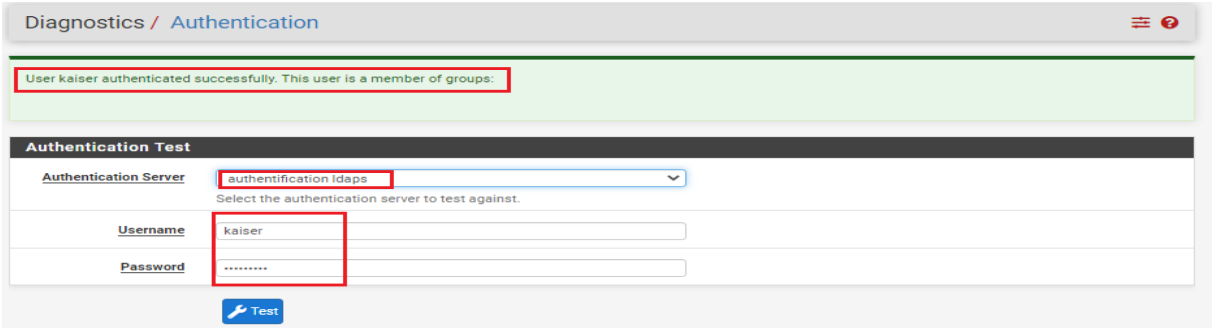


a. Vérification de l'authentification LDAP et LDAPS

- L'authentification Active directory en utilisant LDAP a réussit

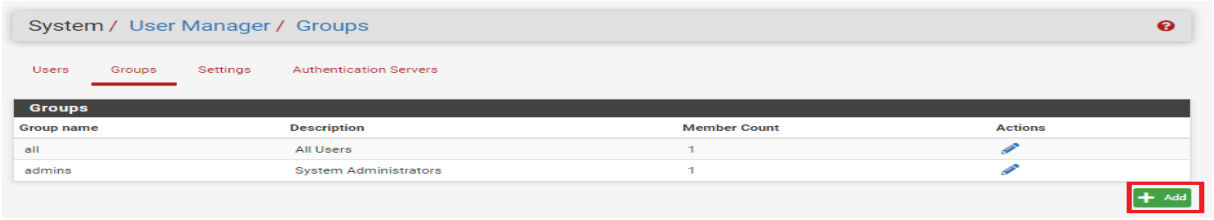


- L'authentification Active directory en utilisant LDAPS a réussit

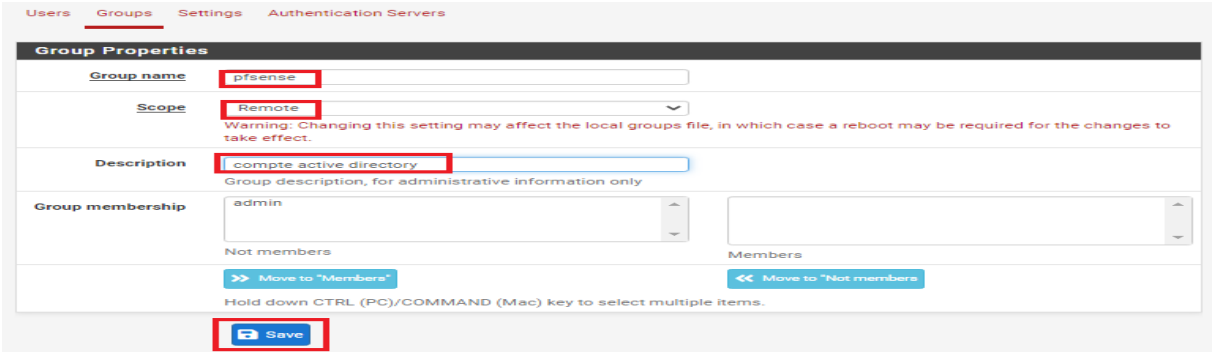


b. Configuration des groupes et des utilisateurs sur pfsense

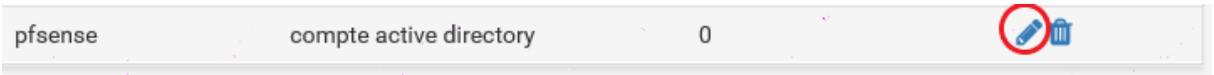
On crée un groupe de même nom que celui crée sur active directory le groupe **pfsense** on clique sur **add** pour rajouter un groupe



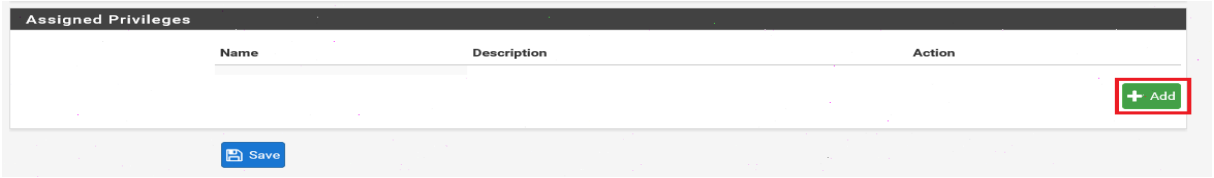
On remplit les champs comme indiqué ci-dessous puis on sauvegarde



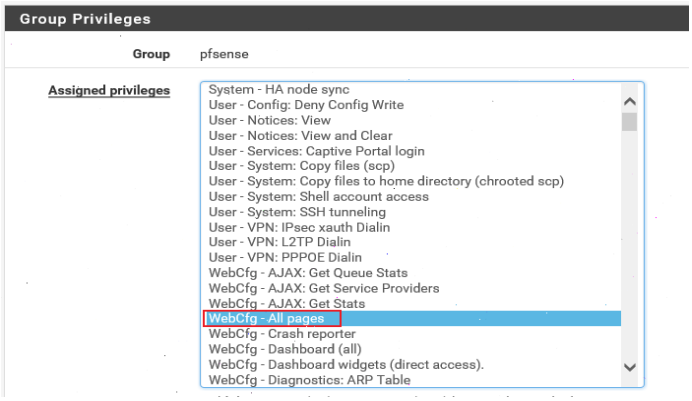
Dès que le groupe est créé je l'édite pour lui donner les droits admin



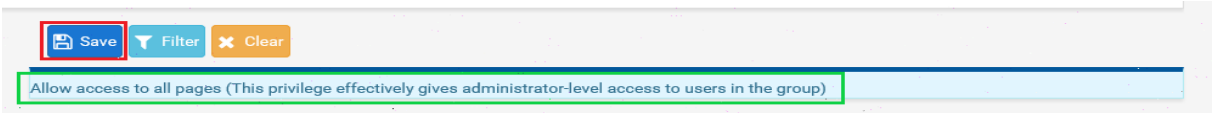
Dans assigned Privilèges je clique sur add



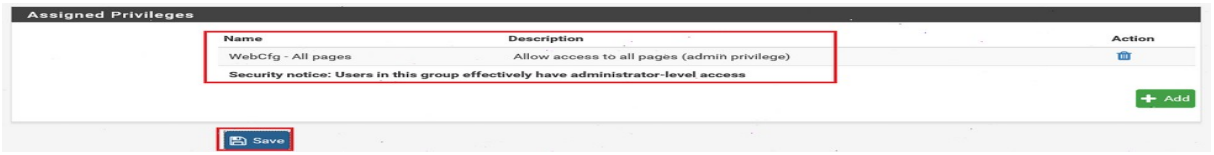
Je sélectionne **WebCfg – All pages** comme droit



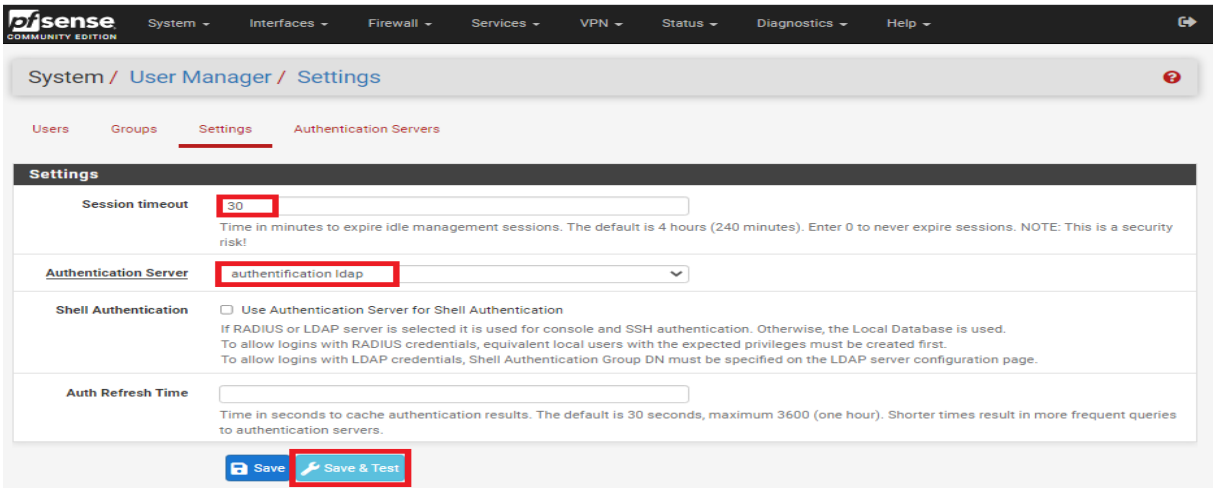
On remarque le groupe pfsense aura tous les droits



On enregistre notre configuration



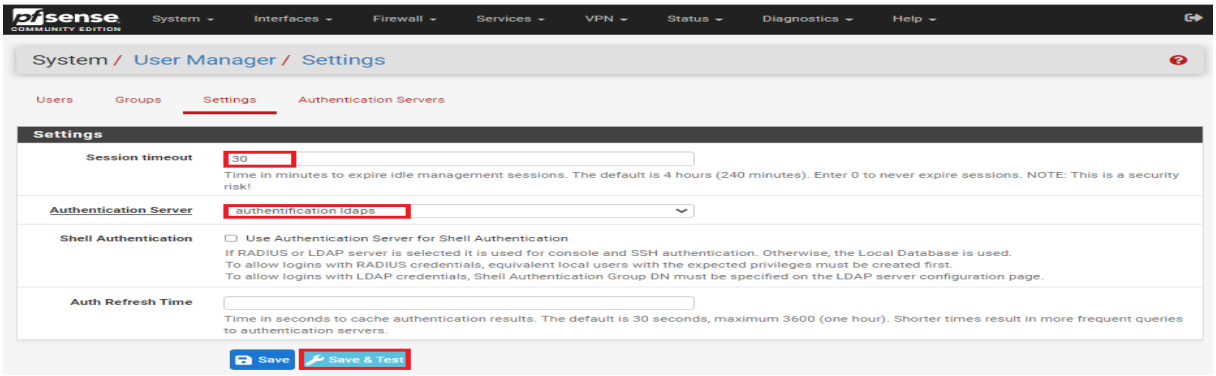
On fait un test de connexion avec la base LDAP



La connexion a réussi



On fait un test de connexion avec la base LDAPS



La connexion a réussi



On teste notre configuration en se connectant avec notre compte **kaiser**



On verifie bien qu'on est connecter avec un compte issue de la base LDAP

